

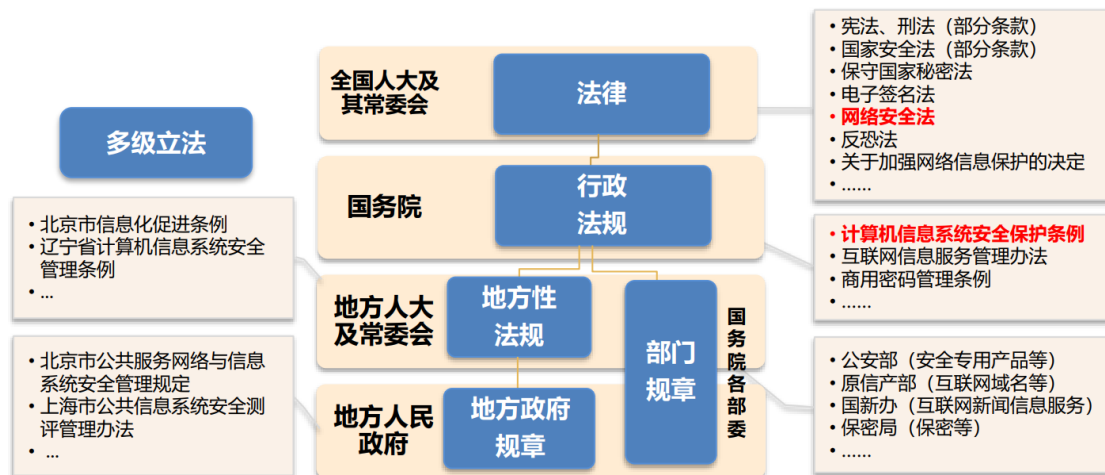
第五讲 信息系统等级保护

一、网络安全法解读

1、整体框架

“防御、 控制与惩治” 三位一体，7 章 79 条。

2、《网络安全法》是网络安全领域的基本法



3、安全等保上升到法律高度，不做等保防护，是属违法!

章节	核心内容解读
第三章 网络运行安全	第一节： ● 国家实行网络安全等级保护制度（第二十一条） ● 网络产品、服务应当符合相关国家标准的强制性要求 ● 网络关键设备和产品应强制取得国家安全标准认证 ● 对网络运营者提共标准的安全职责工作说明 第二节： ● 针对公共通信和信息服务、能源、交通、水利、金融、公共服务、电子政务等重要行业和领域，在网络安全等级保护制度的基础上，实行重点保护 ● 每年至少进行一次检测评估 ● 定期组织安全应急演练
第四章 网络信息安全	个人隐私保护、发布信息监管
第五章 监测预警与应急处置	信息通报制度上升为法律 网络安全预警监测、安全风险评估、应急预案、风险发布
第六章 法律责任	最高 100万 ：违反22/27/33/34/36/38/41/42/43，最高100万，主管10万 最高 50万 ：违反22/24/27/37/46/47/69

二、等级保护

1、什么是等级保护？

网络安全等级保护是指对国家重要信息、法人和其他组织及公民的专有信息以及公开信息和存储、传输、处理这些信息的信息系统分等级实行安全保护，对信息系统中使用的信息安全产品实行按等级管理，对信息系统中发生的信息安全事件分等级响应、处置。



2、国家等级保护制度进入 2.0 时代

2019 年 5 月 13 日，等保 2.0 相关的《信息安全技术网络安全等级保护基本要求》、《信息安全技术网络安全等级保护测评要求》、《信息安全技术网络安全等级保护安全设计技术要求》等国家标准正式发布，并于 2019 年 12 月 1 日开始实施。

3、等级保护制度与关键信息基础设施保护的关系

网络安全等级保护制度是关键信息基础设施保护的基础，关键信息基础设施是等级保护制度的保护重点。

4、构建新的标准体系

《信息安全技术 网络安全等级保护实施指南》 GB/T 25058-20

19

《信息安全技术 网络安全等级保护定级指南》 GB/T 22240

《信息安全技术 网络安全等级保护基本要求》 GB/T 22239-20

19

《信息安全技术 网络安全等级保护安全设计要求》 GB/T 250

70-2019

《信息安全技术 网络安全等级保护测评要求》 GB/T 28448-20

19

《信息安全技术 网络安全等级保护测评过程指南》 GB/T 284

49-2018

5、实施等级保护的意义

明确责任和工作方法，让安全防护更加规范；

提高安全思路 and 意识，合理分配网络安全投资；

改变以往单点防御方式，让安全建设更加体系化。

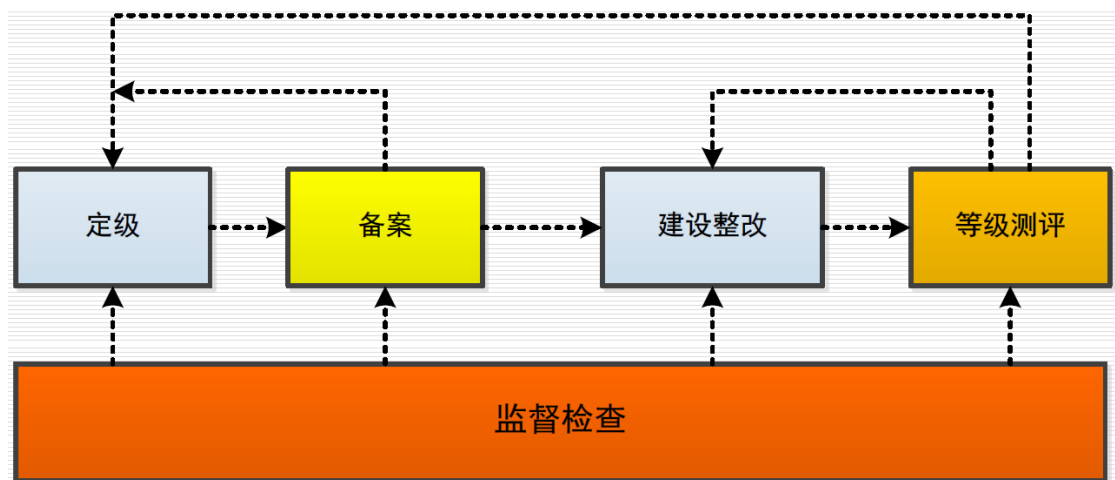
三、等级保护工作流程

1、等级保护管理组织



2、等级保护有“五个规定动作”

网络安全等级保护工作包括**定级、备案、建设整改、等级测评、监督检查**五个阶段。



监督检查是保护能力不断提高的保障。

3、等级保护主要工作流程

《信息安全技术网络安全等级保护定级指南》 GB/T 22240-2020 (2020 年 11 月 1 日实施)

测评周期 (依据信息安全等级保护管理办法):

第二级：每2年测评一次；第三级：每年至少一次；第四级：每半年至少一次；第五级：依据特殊安全需求测评。

等级保护工作实施流程内容		
备案资料准备	定级报告、备案表、网络与信息安全承诺书、网络安全等级保护应急联系登记表、专家评审意见、相关证件原件扫描件等其他备案材料(根据各区分局需要备案材料情况而定)。(以上准备纸质材料是用于去领取备案证明时候提交给公安)	5个工日左右 (看备案单位配快慢)
专家定级评审会	邀请三位专家就信息系统定级情况组织开展定级评审会议，论证信息系统定级的合理性，以及相关备案材料的修改和确定。最终专家签字专家评审意见。	一个工作日
线上提交备案材料进行备案	备案单位可通过互联网使用浏览器访问等保备案预约平台 https://211.101.21.196:3344 ，注册申请本单位账号!注册信息待公安审核几个工作日，下发VPN软件下载地址及登录账号和密码! 通过“查询注册结果”功能查询注册信息审核情况，如公安机关“审核通过”登录vpn相关账号和密码!点击备案申请填写备案信息及提交相关备案材料上传后，待公安对备案材料进行审核，审核通过后待公安通知领取备案证明时间，同时提交纸质版备案材料。领取备案证明后电子版发给测评机构，测评机构办理入场测评登记。	不定 (看公安审核快慢，一般10个工作日内)
差距分析（初测）	依据等级保护测评要求开展等级保护测评工作及漏洞扫描、渗透测试等(初测)出具差距分析报告及整改意见	10个工作日左右
安全整改	备案单位依据整改并结合企业的自身情况进行信息系统整改	不定(看备案单位整改快慢)
等级测评	依据等级保护测评要求开展等级保护测评工作(复测)	7个工作日左右
测评报告	测评机构进行等级测评报告编制、出具	15个工作日左右
提交测评报告	测评机构把测评报告盖章后给备案单位，备案单位提交给网安大队。整条项目结束。	10个工作日左右

4、定级

(1) 重要行业关键信息系统划分及定级建议

国家信息安全等级保护坚持自主定级、自主保护的原则。

信息系统的安全保护等级应当根据信息系统在国家安全、经济建设、社会生活中的重要程度，信息系统遭到破坏后对国家安全、社会秩序、公共利益以及公民、法人和其他组织的合法权益的危害程度等因素确定。

保护对象级别	重要性程度	监督管理强度等级
第一级	一般系统	自主保护级
第二级	一般系统	指导保护级
第三级	重要系统/关键信息基础设施	监督保护级
第四级	关键信息基础设施	强制保护级
第五级	关键信息基础设施	专控保护级

等级	对象	侵害客体	侵害程度	监管强度
第一级	一般系统	合法权益	损害	自主保护
第二级		合法权益	严重损害	指导
		社会秩序和公共利益	损害	
第三级	重要系统	社会秩序和公共利益	严重损害	监督检查
		国家安全	损害	
第四级		社会秩序和公共利益	特别严重损害	强制监督检查
		国家安全	严重损害	
第五级	极端重要系统	国家安全	特别严重损害	专门监督检查

(2) 定级实例

等级	等级定义	适用系统
第一级 自主保护	信息系统受到破坏后，会对公民、法人和其他组织的合法权益造成损害，但不损害国家安全，社会秩序和公共利益。	个人博客等
第二级 指导保护	信息系统受到破坏后，会对公民、法人和其他组织的合法权益产生严重损害，或者对社会秩序和公共利益造成损害，但不损害国家安全。	普通网站，小门户等
第三级 监督保护	信息系统受到破坏后，会对公民、法人和其他组织的合法权益产生严重损害，或者对国家安全造成损害。	用户量较大的系统，存储有敏感信息的系统
第四级 强制保护	信息系统受到破坏后，会对公民、法人和其他组织的合法权益产生严重损害，或者对国家安全造成严重损害。	银行核心电力调度等
第五级 专控保护	信息系统受到破坏后，会对公民、法人和其他组织的合法权益产生严重损害，会对国家安全造成特别严重损害。	不能打听

(3) 定级对象

也称**等级保护对象**、网络安全等级保护工作的作用对象。

包括**网络基础设施**（广电网、电信网、专用通信网络等）、云计算平台系统、大数据平台系统、物联网、工业控制系统、采用移动互联技术的系统等。

5、备案

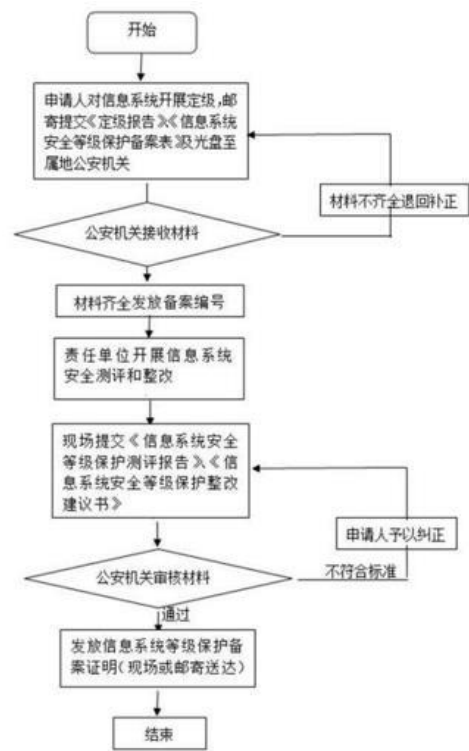
(1) 备案的依据

《信息安全等级保护备案实施细则》(公信安【2007】1360 号)

注意：将会根据网络安全等级保护条例进行调整

(2) 备案的流程

运营、使用单位在确定等级后到所在地的市级及以上公安机关备案。



- 新建二级及以上信息系统在投入运营后 30 日内、已运行的二级及以上信息系统在等级确定 30 日内备案。
- 公安机关对信息系统备案情况进行审核，对符合要求的在 10 个工作日内颁发等级保护备案证明。
- 对于定级不准的，应当重新定级备案。对于重新定级的，公安机关一般会建议备案单位组织专家进行重新定级评审并报上级主管部门审批。

(3) 备案地点

① 二级以上信息系统

由信息系统运营使用单位（备案单位）到地市级以上公安机关网络安全保卫部门办理备案手续，填写《信息系统安全等级保护备案表》。

②隶属于省级的备案单位

其跨地（市）联网运行的信息系统，由省级公安机关网络安全保卫部门受理备案。

③隶属于中央的在京单位

其跨省或者全国统一联网运行并由主管部门统一定级的信息系统，由主管部门向公安部备案。

④跨省或者全国统一联网运行的信息系统

在各地运行、应用的分支系统，由所在地地市级以上公安机关网络安全保卫部门受理备案。

⑤各部委统一定级信息系统在各地的分支系统

即使是上级主管部门定级的，也要到当地公安网络安全保卫部门备案。

（4）信息系统安全等级保护备案表

①单位基本情况

②信息系统情况

③信息系统定级情况

④第三级以上信息系统提交材料情况

（5）公安机关受理备案

公安机关受理备案，按照《信息安全等级保护备案实施细则》要求，对备案材料进行审核，定级准确、材料符合要求的颁发由公安部统一监制的**备案证明**。

（6）定级备案基本流程总结

①用户初步定级

②编写定级报告

③专家定级评审

④填写备案表

⑤提交备案材料

⑥收到备案证明

6、建设整改

使确定了等级的信息系统能够达到相应等级的基本保护水平和满足自身需求的安全保护能力。

运营使用单位按照管理规范和技术标准，选择管理办法要求的信息安全产品，建设符合等级要求的信息安全设施，建立安全组织，制定并落实安全管理制度。

对于未达到安全等级保护要求的，运营、使用单位应当进行整改。整改完成应当将整改报告报公安机关备案。

7、《网络安全等级保护基本要求》 GB/T 22239 2019

(1) 由 10 个章节 8 个附录构成

1. 范围

2. 规范性引用文件

3. 术语定义

4. 缩略语

5. 网络安全等级保护概述

6-10 五个等级的安全要求

附录 A 安全要求的选择和使用

附录 B 关于等级保护对象整体安全保护能力的要求

附录 C 等级保护安全框架和关键技术使用要求

附录 D 云计算应用场景说明

附录 E 移动互联应用场景说明

附录 F 物联网应用场景说明

附录 G 工业控制系统应用场景说明

附录 H 大数据应用场景说明

(2) 增加云计算安全扩展要求

云计算安全扩展要求章节针对云计算的特点提出特殊保护要求。对云计算环境主要增加的内容包括“基础设施的位置”、“虚拟化安全保护”、“镜像和快照保护”、“云服务商选择”和“云计算环境管理”等方面。

云计算安全扩展要求原则性要求：

- ① 应确保云计算平台不承载高于其安全保护等级的业务应用系统。
- ② 应确保云计算基础设施位于中国境内。
- ③ 云计算平台的运维地点应位于中国境内，如需境外对境内云计算平台实施运维操作应遵循国家相关规定。
- ④ 云计算平台运维过程产生的配置数据、鉴别数据、业务数据、日志信息等存储于中国境内，如需出境应遵循国家相关规定。

主要技术思想：

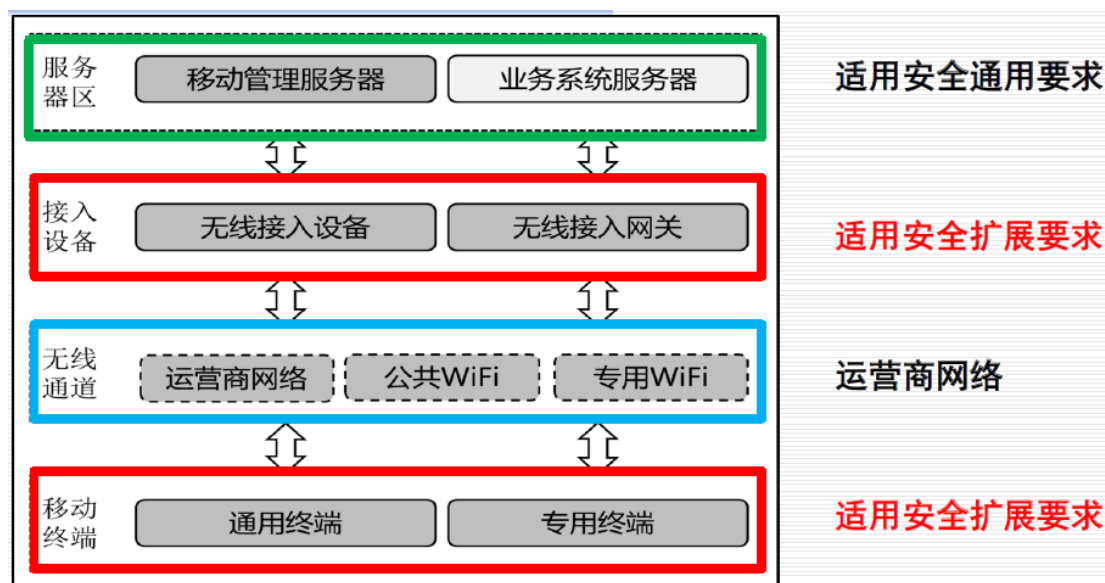
- 云计算平台（采用云计算技术的系统）自身安全防护要求。
- 云计算平台向其上租户系统提供安全防护的能力要求。

网络架构

c) 应具有根据云服务客户业务需求提供通信传输、边界防护、入侵防范等安全机制的能力；

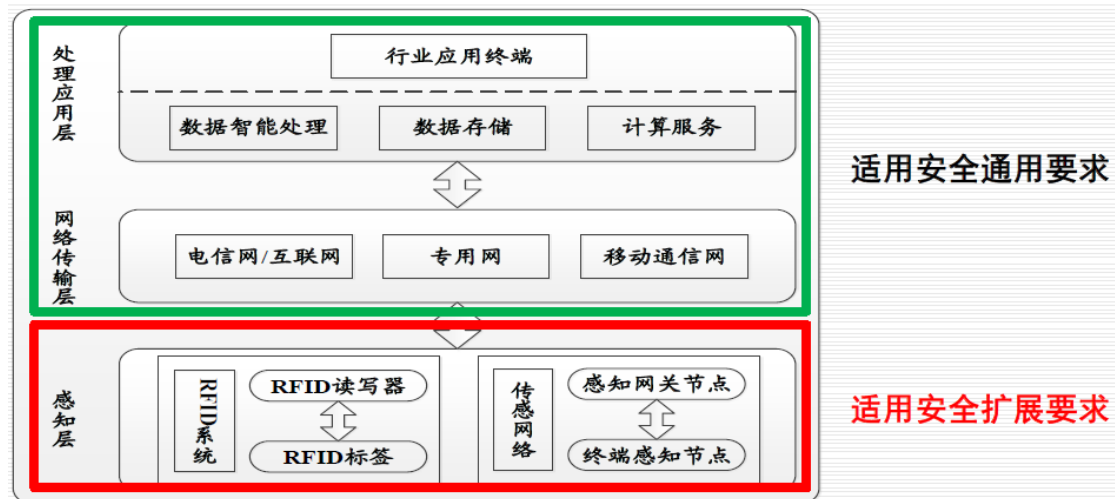
(3) 增加移动互联安全扩展要求

移动互联安全扩展要求章节针对移动互联的特点提出特殊保护要求。对移动互联环境主要增加的内容包括“无线接入点的物理位置”、“移动终端管控”、“移动应用管控”、“移动应用软件采购”和“移动应用软件开发”等方面。



(4) 增加物联网安全扩展要求

物联网安全扩展要求章节针对物联网的特点提出特殊保护要求。对物联网环境主要增加的内容包括“感知节点的物理防护”、“感知节点设备安全”、“感知网关节点设备安全”、“感知节点的管理”和“数据融合处理”等方面。



(5) 增加工业控制系统安全扩展要求

■ 工业控制系统安全扩展要求主要针对现场控制层和现场设备层提出特殊安全要求，其他层次使用安全通用要求条款。

■ 对工业控制系统的保护需要根据实际情况使用基本要求，具体安全通用要求和安全扩展要求的使用方法比较复杂。

工业控制系统安全扩展要求章节针对工业控制系统的特点提出特殊保护要求。

工业控制系统主要增加的内容包括“室外控制设备防护”、“业控系统网络架构安全”、“拨号使用控制”、“无线使用控制”和“控制设备安全”等方面，针对工业控制系统实时性要求高的特点调整了“漏洞和风险管理”和“恶意代码防范管理”方面的要求。

(6) 安全物理环境